

# FTP-to-SSH Exploit Lab

## Tổng Quan

Bài lab này mô phỏng một kịch bản bảo mật thực tế với kiến trúc **client-server** trong Docker network. Bạn sẽ sử dụng một client container để tấn công vào server container trong cùng một mạng nội bộ.

**Kiến trúc:** - **Server Container** (`ftp-ssh-server`): Target với web, FTP, SSH services - **Client Container** (`ftp-ssh-client`): Attacker machine với penetration testing tools - **Internal Network**: Containers giao tiếp qua Docker network, không expose ports ra ngoài

**Mục tiêu học tập:** - Hiểu về cấu hình sai của dịch vụ FTP (anonymous login) - Khai thác lỗ hổng để upload SSH key - Thực hiện lateral movement giữa các dịch vụ - Làm việc trong môi trường Docker network - Nắm bắt flag từ hệ thống

## Cài Đặt Nhanh

### Yêu Cầu

- Docker
- Docker Compose
- FTP client (ví dụ: `ftp` command hoặc FileZilla)
- SSH client

### Khởi Động Lab

```
cd ftp-ssh-lab
docker-compose up -d
```

### Kiểm Tra Trạng Thái

```
docker-compose ps
docker-compose logs
```

## Kiến Trúc Lab

### Containers

| Container             | Hostname       | Vai Trò  | Services                                 |
|-----------------------|----------------|----------|------------------------------------------|
| <b>ftp-ssh-server</b> | ftp-ssh-server | Target   | Web (80), FTP (21), SSH (22)             |
| <b>ftp-ssh-client</b> | ftp-ssh-client | Attacker | FTP client, SSH client, nmap, curl, etc. |

## Truy Cập Lab

### Bước 1: Khởi động lab

```
cd /home/ubuntu/Desktop/bangiaolab/ftp-ssh-lab
docker compose up -d
```

### Bước 2: Exec vào client container

```
docker exec -it ftp-ssh-client bash
```

### Bước 3: Từ client, truy cập các dịch vụ trên server

```
# Web Interface
curl http://ftp-ssh-server
```

```
# FTP Server
ftp ftp-ssh-server
# Username: anonymous
# Password: (để trống)
```

```
# SSH Server
ssh dev01@ftp-ssh-server
# Yêu cầu SSH key
```

```
# Port Scanning
nmap ftp-ssh-server
```

## Thử Thách

Bạn được cung cấp quyền truy cập vào một hệ thống có 3 dịch vụ đang chạy. Mục tiêu của bạn là:

1. **Khám phá** các dịch vụ đang chạy
2. **Tìm kiếm** lỗ hổng bảo mật
3. **Khai thác** để có quyền truy cập SSH
4. **Chiếm lấy flag** từ hệ thống

**Flag format:** FLAG{...}

**Vị trí flag:** Nằm trong thư mục home của user **dev01**. Flag có thể nhìn thấy qua FTP nhưng không thể đọc trực tiếp do permissions.

## Gợi Ý

Gợi ý 1: Khám phá dịch vụ

Hãy thử kết nối đến tất cả các dịch vụ. Dịch vụ nào không yêu cầu xác thực?

Gợi ý 2: FTP Anonymous và Home Directory

FTP server cho phép anonymous login. Sau khi đăng nhập, bạn đang ở đâu? Hãy liệt kê các files và thư mục. Bạn có thấy gì thú vị không?

Gợi ý 3: Permission Denied

Bạn có thể thấy flag file nhưng không thể đọc nó qua FTP. Điều này có nghĩa là gì? Làm thế nào để đọc được file này?

Gợi ý 4: SSH Key và .ssh Directory

SSH server chỉ chấp nhận key-based authentication. Bạn có thể upload SSH public key vào đâu đó không? Hãy tìm thư mục `.ssh` trong FTP.

Gợi ý 5: Kết nối các mảnh ghép

Nếu bạn có thể upload file qua FTP vào thư mục `.ssh` và SSH yêu cầu key... có cách nào để kết hợp 2 điều này không? File nào cần được upload?

## Công Cụ Hữu Ích

- `ftp` - FTP client
- `ssh-keygen` - Tạo SSH key pair
- `ssh` - SSH client
- `nmap` - Port scanning (optional)
- `curl` hoặc trình duyệt web

## Dọn Dẹp

Để dừng và xóa lab:

```
docker-compose down
```

Để xóa hoàn toàn (bao gồm volumes):

```
docker-compose down -v
```

## Tài Liệu Tham Khảo

- Hướng dẫn giải chi tiết - **CẢNH BÁO: SPOILER!**
- Mô tả chi tiết lab

## Lưu Ý Bảo Mật

Lab này được thiết kế cho mục đích **học tập** và **nguyên cứu bảo mật**.

**KHÔNG BAO GIỜ:** - Sử dụng cấu hình này trong môi trường production  
- Mở các port này ra internet công cộng - Sử dụng anonymous FTP trong hệ thống thực tế

## Thông Tin Kỹ Thuật

**Các lỗ hổng được mô phỏng:** - Anonymous FTP với quyền upload - FTP root directory mapped vào home directory của user - Misconfigured file permissions (flag readable by owner/group only, .ssh writable by everyone) - SSH StrictModes disabled - Service enumeration

**Kỹ thuật tấn công:** - Service discovery - Anonymous access exploitation - SSH key injection - Privilege escalation (user-level)

## Đóng Góp

Nếu bạn tìm thấy bug hoặc có ý tưởng cải thiện, vui lòng tạo issue hoặc pull request.

## License

Lab này được tạo cho mục đích giáo dục. Sử dụng có trách nhiệm.

---

Chúc bạn may mắn!